

CONFIGURING & SECURING CASELIGHT

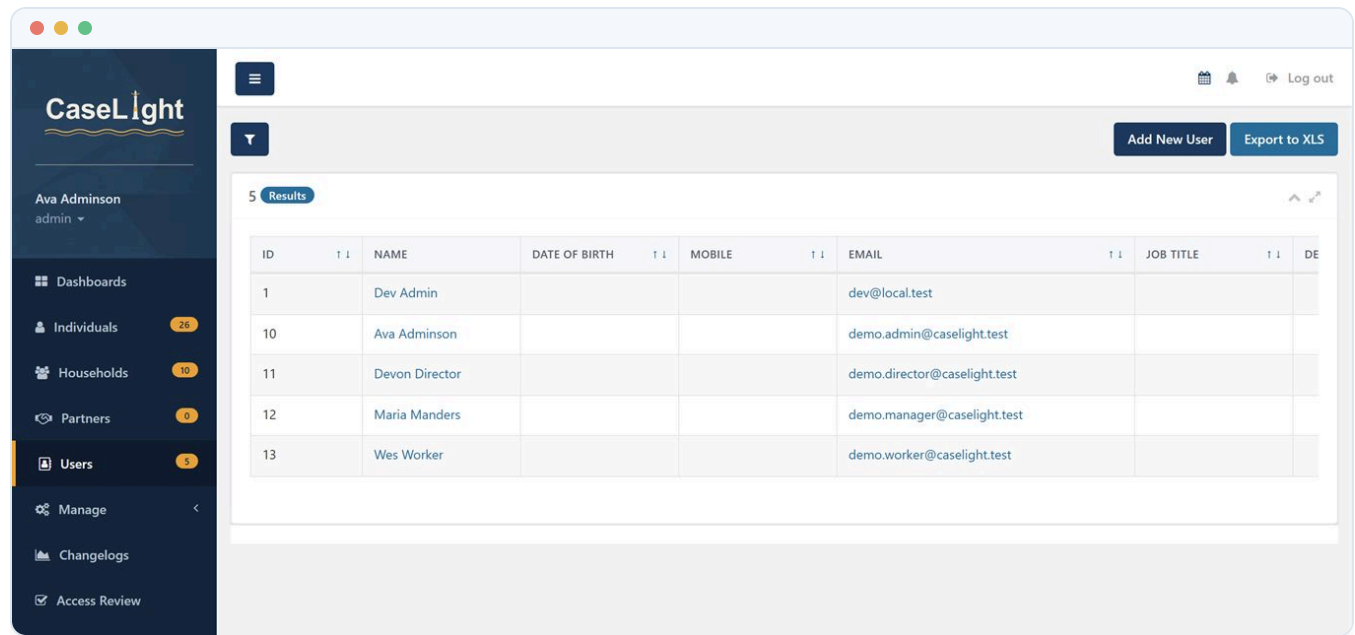


Administrator Guide

Set up users, tailor the system to your programs without code, and operate its security controls — everything under **Manage** and the admin surfaces.

1 Users & access

Under **Users**, add a staff account for each person and assign a role — the role decides what they can see and do (see the User Guide's role table). Add a user, set their role, and export the roster to XLS.



The screenshot shows the CaseLight web application interface. On the left is a dark sidebar with the CaseLight logo and a navigation menu including Dashboards, Individuals (25), Households (10), Partners (9), Users (5), Manage, Changelogs, and Access Review. The main content area is titled 'Users' and shows a table with 5 results. The table has columns for ID, NAME, DATE OF BIRTH, MOBILE, EMAIL, JOB TITLE, and DE. The data rows are as follows:

ID	NAME	DATE OF BIRTH	MOBILE	EMAIL	JOB TITLE	DE
1	Dev Admin			dev@local.test		
10	Ava Adminson			demo.admin@caselight.test		
11	Devon Director			demo.director@caselight.test		
12	Maria Manders			demo.manager@caselight.test		
13	Wes Worker			demo.worker@caselight.test		

At the top right of the main area are buttons for 'Add New User' and 'Export to XLS'. The top right corner of the application shows a 'Log out' link.

Users — one account per staff member.

Access Review — periodic recertification

The **Access Review** report (AC-2) lists every account with its role, last sign-in, MFA and passkey status, and whether it's locked or disabled. It flags **disabled staff who still hold caseloads**, and summarizes the least-privilege and authorization shadow windows. Export to CSV for your records.

CaseLight

Ava Adminson
admin

Access Review
Periodic recertification (AC-2(j)). PER TENANT - run once per subdomain to cover all staff.

Export CSV

NAME	EMAIL	ROLE	LAST SIGN IN	COUNT	MFA	PASSKEYS	LOCKED	DISABLED	CREATED
Ava Adminson	demo.admin@caselight.test	admin	2026-07-08 23:59	1	off	0			2026-07-08
Dev Admin	dev@local.test	admin	2026-07-08 21:49	102	on	1			2026-06-21
Devon Director	demo.director@caselight.test	strategic overviewer		0	off	0			2026-07-08
Maria Manders	demo.manager@caselight.test	manager		0	off	0			2026-07-08
Wes Worker	demo.worker@caselight.test	case worker		0	off	0			2026-07-08

Disabled Staff Still Holding Caseloads
These accounts cannot sign in (disabled) but still have clients assigned. Reassign their caseloads so work is not routed to a dead account.
None — no disabled account holds a caseload.

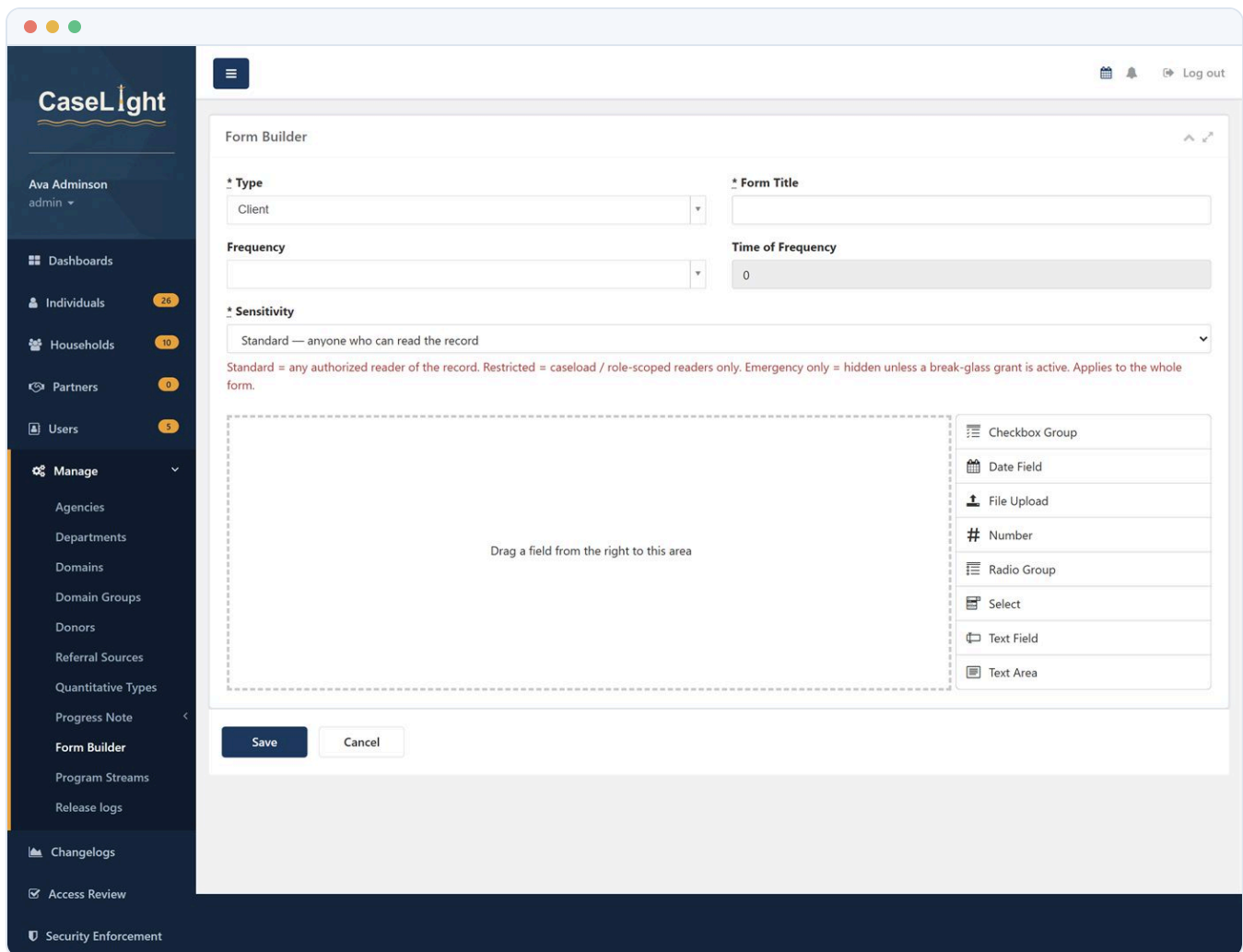
Least-Privilege Shadow Divergences
AC-6 shadow window (enforcement OFF). How often the narrowed rules WOULD have denied access, per staff member. Review before enabling enforcement.
No shadow divergences recorded yet.

Authorization-Cutover Shadow (AC-3)
Global authorization cutover shadow window (enforcement OFF). Actions that WOULD fail the mandatory authorization check, by controller/action/role. Review before flipping enforce_authorization.
No authorization-cutover divergences recorded yet.

Access Review – recertify accounts and catch orphaned caseloads.

2 Configure without code: the form builder

Rather than editing the data model, add **custom forms** (attachable to individuals, households, users, or partners) with a drag-and-drop builder under **Manage** → **Form Builder**.



The form builder – choose type, frequency, and the form's sensitivity, then drag in fields.

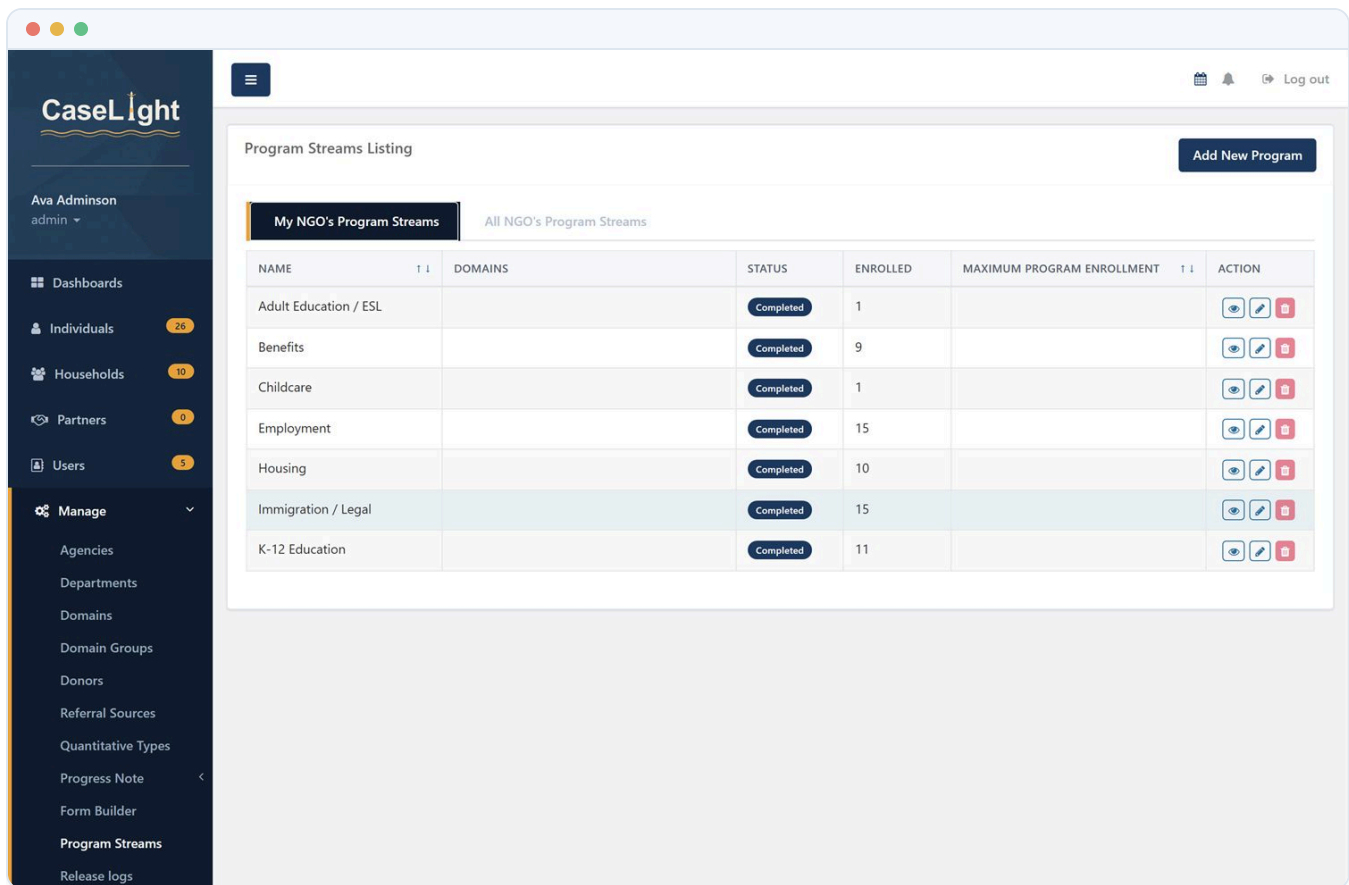
Every form carries a **sensitivity**, set at design time:

- ◆ **Standard** — any authorized reader of the record.
- ◆ **Restricted** — caseload- or role-scoped readers only.
- ◆ **Emergency only** — hidden unless a **break-glass** grant is active (see §6).

Because sensitivity is chosen when the form is designed, a brand-new form can never accidentally expose data — it inherits an explicit classification from the start.

3 Program streams

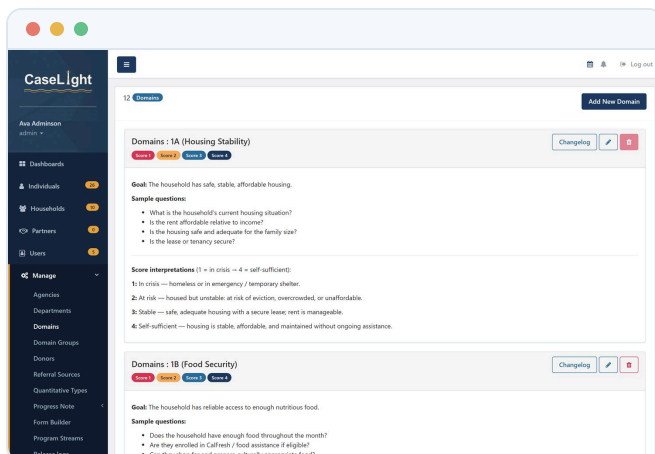
Define the programs your organization actually runs under **Manage → Program Streams**. Each stream is enrollable, has its own custom form, and supports recurring, date-stamped trackings.



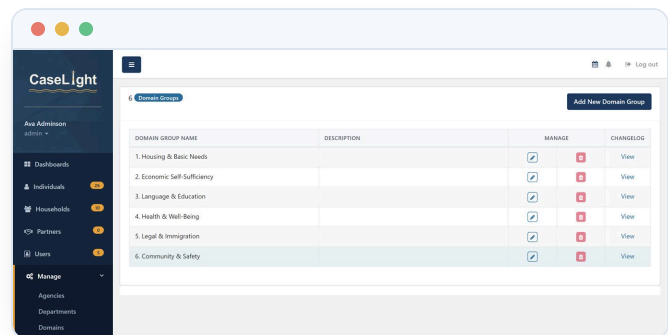
Program streams – the enrollable programs behind every case.

4 Assessment domains & groups

The assessment engine scores needs across life **domains**, organized into **domain groups**. Configure both under **Manage**, and set each domain's **sensitivity** so the most protected domains stay restricted.



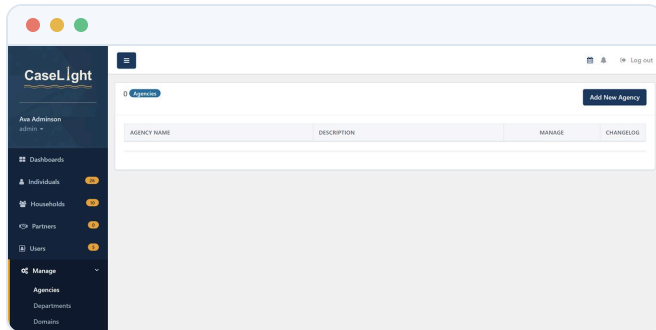
Domains (with sensitivity).



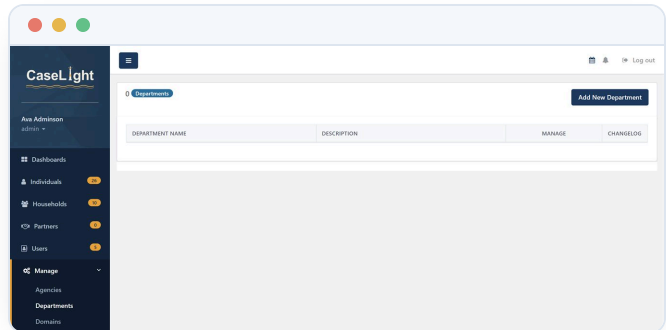
Domain groups.

5 Reference data

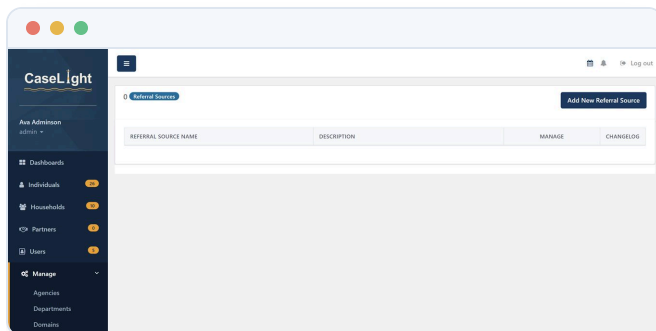
The lists that populate dropdowns and organize your work — all editable under **Manage**. Keep them tidy and every record downstream stays consistent.



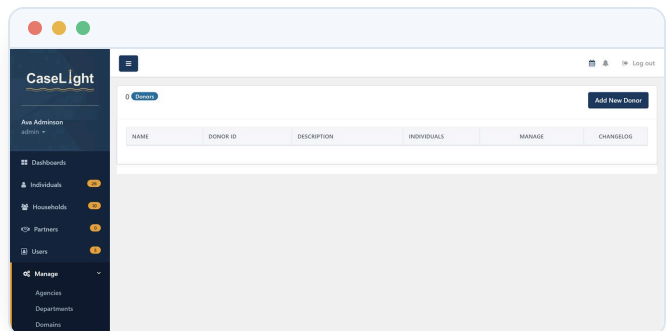
Agencies – partner and referring organizations.



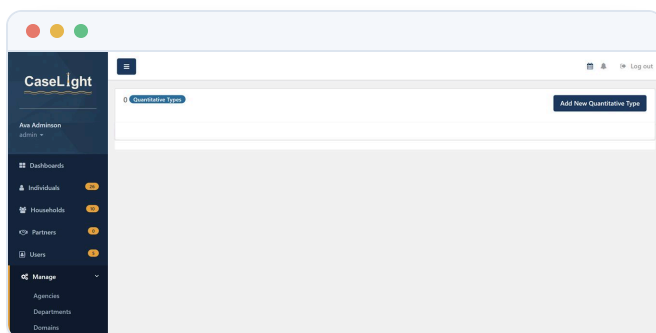
Departments – internal structure for staff.



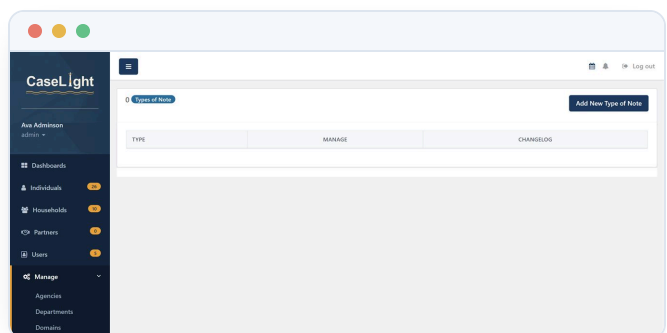
Referral sources – how clients reach you.



Donors – funding sources for reporting.



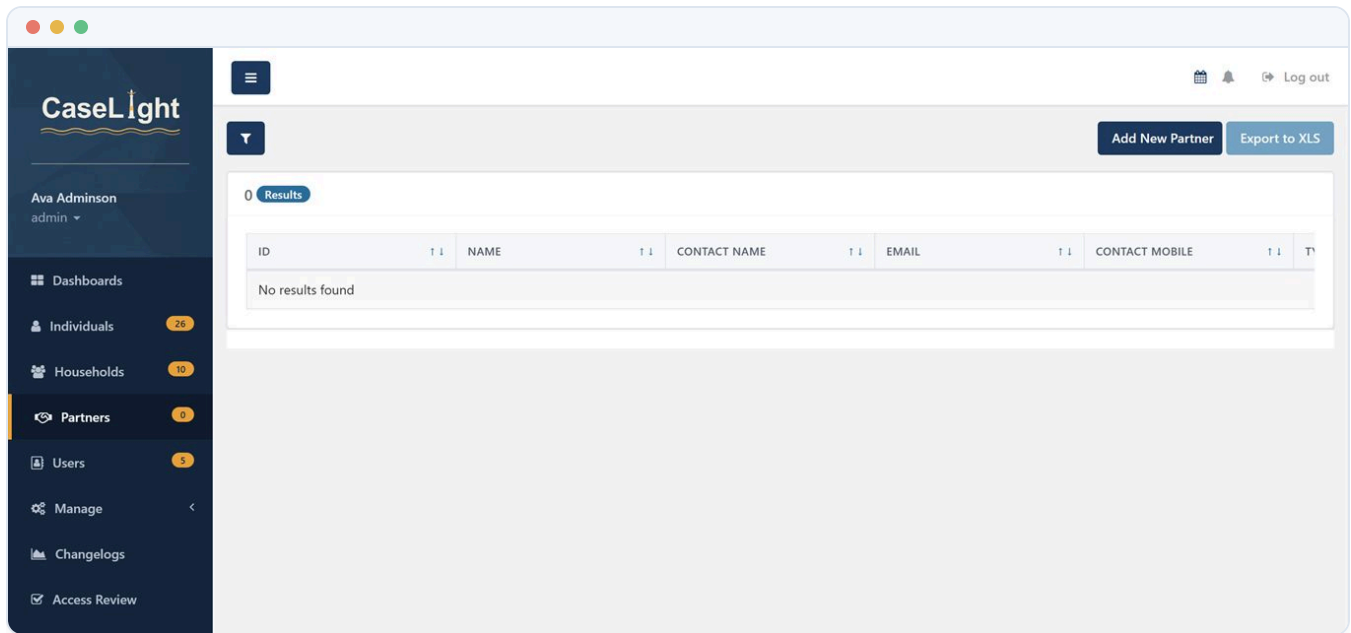
Quantitative types – countable service categories.



Types of Note – categories for progress notes.

Partners

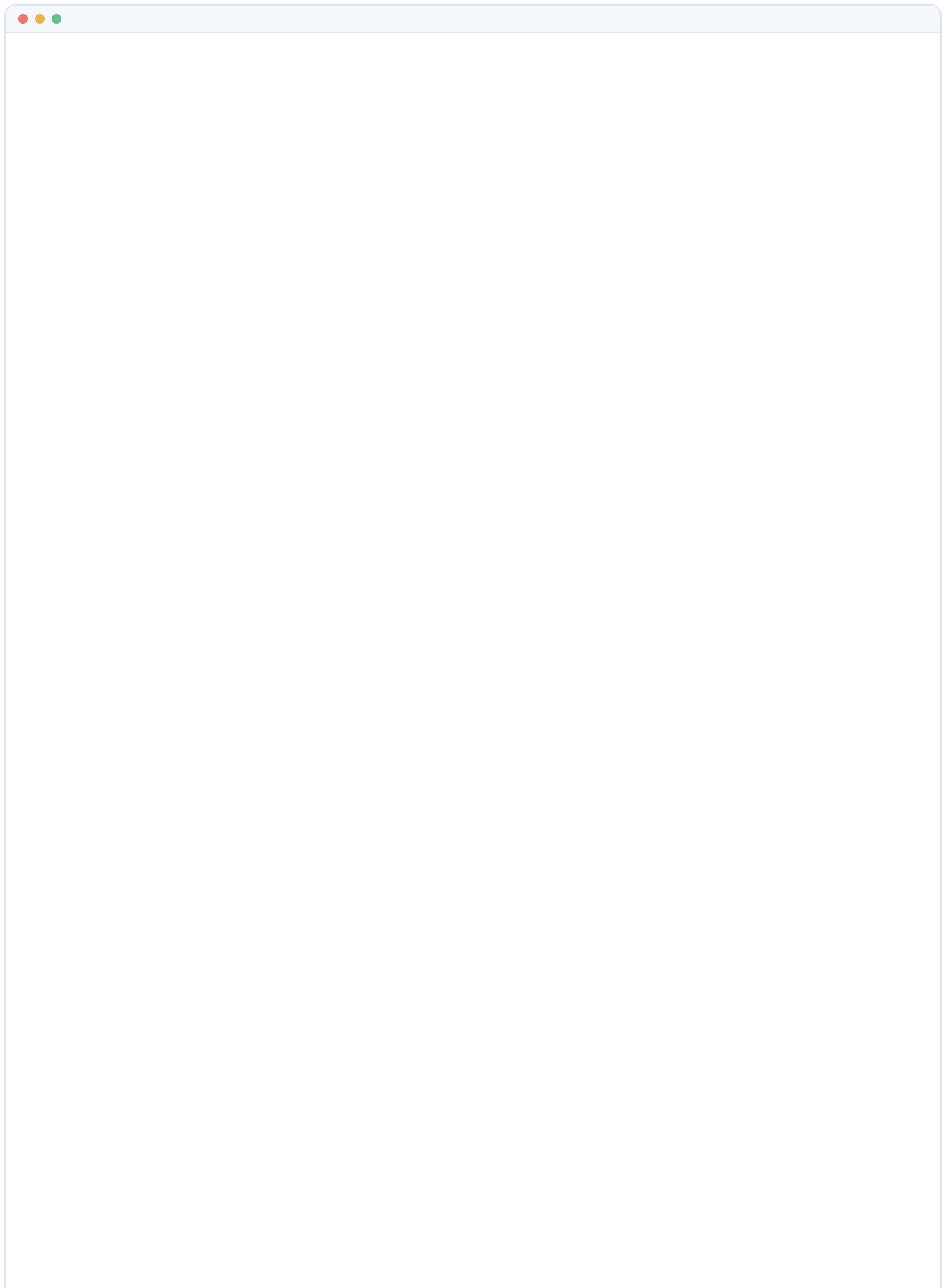
External **Partners** (agencies you coordinate with) get their own records and custom forms, tracked separately from the individuals you serve.



Partners.

6 Security enforcement & break-glass

The **Security Enforcement** panel turns live security controls on or off **for your organization**, each mapped to a NIST 800-53 control, and each showing a **shadow window** — what the stricter rule *would* have denied — so you can review impact before enabling.



CaseLight

Ava Adminson
admin

Dashboards

Individuals26

Households10

Partners0

Users5

Manage

Changelogs

Access Review

Security Enforcement

Security Enforcement

Runtime control of this organization's Phase-5 security enforcement flags.

Scope: this organization only (cases)

These switches ENABLE or DISABLE live security enforcement for THIS organization. Review the shadow findings below BEFORE enabling. Turning on authorization enforcement makes every action require explicit authorization.

Global authorization enforcement (AC-3)

shadow / offsystem default

Requires every controller action to explicitly authorize. When enabling, review the authorization-cutover shadow below — any action listed WOULD return 403.

Use system default

Authorization-cutover shadow — would-403 (review before enabling)

No shadow divergences recorded yet.

Least-privilege narrowing (AC-6)

shadow / offsystem default

Scopes progress-note and version reads to need-to-know. When enabling, review the least-privilege shadow below — any row listed WOULD be denied.

Use system default

Least-privilege shadow — would-deny (review before enabling)

No shadow divergences recorded yet.

Tenant-boundary tripwire (SC-7)

ENFORCINGpersisted override

Refuses any request whose data schema does not match the host tenant. Under normal operation zero mismatches are expected.

Enforcing

0 tenant-mismatch event(s) recorded (0 expected).

Require two-factor authentication (all users) (IA-2(1))

system default

When On, every signed-in user without 2FA is redirected to enroll before continuing. The default nudges only privileged (admin/manager) accounts. This is an enrollment prompt, never a lockout — the enrollment page and this settings page stay reachable.

Use system default

Idle session timeout (AC-12)

Minutes of inactivity before a session is invalidated and re-authentication is required. Blank uses the system default (30 minutes). Allowed range 1-1440.

Idle timeout (minutes)

System default (30)

Leave blank to use the system default (30).

Account lockout threshold (AC-7)

Consecutive failed sign-ins before an account is locked, and how long until it auto-unlocks. Blank uses the system defaults (10 attempts / 60 minutes). For safety, the attempt threshold cannot be set below 3 — a lower value could lock out administrators after a couple of typos.

Max failed attempts (minimum 3)

Lockout max attempts

Auto-unlock after (minutes)

Lockout unlock in minutes

Password expiry / rotation (IA-5)

Maximum password age in days. When set, a user whose password is older is prompted to change it at next login (never locked out; the change-password page requires the current password and enforces complexity + no-reuse). Blank means passwords never expire (recommended per NIST 800-63B unless a policy requires rotation).

Max password age (days)

CaseLight — Administrator Guide

Page 9 of 11

no expiry (default)

Leave blank for no expiry (the default).

Inactive-account auto-disable (AC-2(3))

Days of inactivity (no sign-in) before a staff account is automatically disabled by the daily maintenance run. A disabled account cannot sign in but keeps its records and can be re-enabled from its user page. The last enabled administrator is never auto-disabled. Blank means the daily run only reports would-be candidates and disables nobody.

Disable after inactive (days, minimum 30)

Off — report only (default)

Leave blank to keep auto-disable off (the daily run stays report-only).

Save enforcement settings

Open the full Access Review report

Last changed by dev@local.test at 2026-07-01 18:24

Security Enforcement – per-organization control toggles.

Global authorization Require every action to authorize explicitly. AC-3	Least-privilege narrowing Scope reads to need-to-know. AC-6
Tenant-boundary tripwire Refuse any cross-tenant request. SC-7	MFA & idle timeout Require MFA; invalidate idle sessions. IA-2 • AC-12
Lockout & password expiry Lock after failed sign-ins; rotate passwords. AC-7 • IA-5	Inactive-account auto-disable Disable dormant accounts automatically. AC-2(3)

Break-glass emergency access

When a genuine life-safety need requires an **emergency-only** field, an eligible worker can **self-elevate for one hour** — with a mandatory reason and the audit record written *first*. Access is scoped to the specific record, expires automatically, and is fully logged.

7 Data protection & privacy

CaseLight is hardened at the application layer toward NIST 800-53 Moderate and SOC 2 (Security, Confidentiality, Privacy), and aligns with the HIPAA Security Rule.

- ◆ **Field-level sensitivity** — Standard / Restricted / Emergency-only on forms and domains; records mask what a role isn't cleared to see.
- ◆ **Encryption at rest** — sensitive PII is encrypted in the database across multiple tiers.

- ◆ **Append-only audit trail** — reads and changes logged to a separate, tenant-isolated store, with change history and retention.
- ◆ **Tenant isolation** — each organization is its own subdomain and database schema.
- ◆ **Data lifecycle** — retention/deletion routines, guarded and audited deletion, and a subject-access export.

Hardened toward **NIST 800-53** Moderate

SOC 2 · Security · Confidentiality · Privacy

Aligned to the **HIPAA** Security Rule

AGPL-3.0

The full compliance package — System Security Plan, SOC 2 control matrix, policies, POA&M, and a reproducible **rake compliance:evidence** bundle — lives in **docs/compliance/**. Data-handling posture and the production gate for **real** client data are in **SECURITY.md**. **Pilot data is synthetic only.**